/\/ nebulock

AGENTIC THREAT HUNTING

HUNT WITH MEMORY. HUNT WITH AGENTS.

AGENTIC THREAT HUNTING FRAMEWORK — OPEN SOURCE, YOURS TO KEEP.

WHO'S RUNNING THIS

Sydney Marrone · Eric Brown · Jarrett Polcari

Three of us built this workshop and three of us are teaching it — curriculum, telemetry, and infrastructure.

Nebulock · THOR Collective

KUDOS TO THE CREW BEHIND IT

- **Joshua Hines** · **Alex Hurtado** · **Brandon Schwartz** — ran every module and every lab before you did, cold, with no answer key.
- **Ray Salamon** — made sure we didn't break the internet doing this.
- Every rough edge they hit is one you won't.

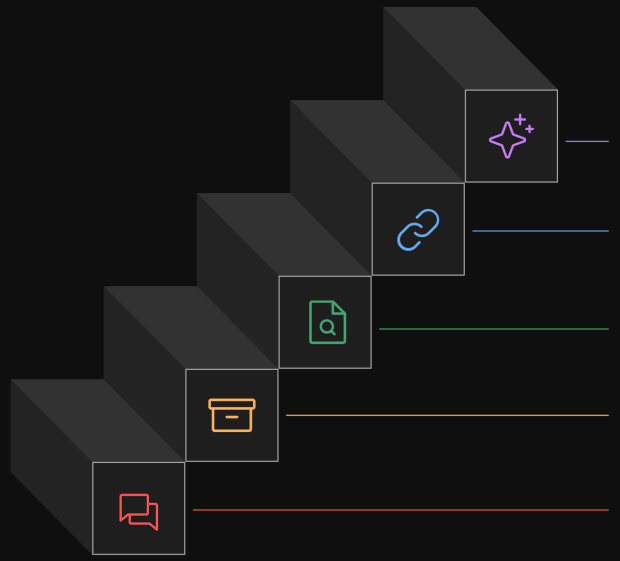
THEY HUNTED THE WORKSHOP SO YOU CAN HUNT THE INTRUSION.

THE FIVE LEVELS OF AGENTIC HUNTING

LEVEL	NAME	WHAT IT MEANS	ATHF
L0	**AD-HOC**	Hunt in a search bar. Close laptop, hunt is gone.	—
L1	**DOCUMENTED**	Write the hunt down so it survives you.	`hunt new`
L2	**SEARCHABLE**	Find the next hunt by reusing the last.	`similar`
L3	**GENERATIVE**	Agent reads intel, hands you hypotheses.	`research new`
L4	**AGENTIC**	Agent has tools; finds what you haven't covered.	mcp

THE MEMORY IS THE MOAT.

The Five Levels of Agentic Hunting



5 Agentic
Multi-agent workflows share structured memory to create and validate hunts.

4 Generative
AI connects to security tools for automated queries.

3 Searchable
AI reads and recalls context from past hunts.

2 Documented
Hunts are structured and stored in markdown files.

1 Manual
Hunts are managed through informal channels like Slack or tickets.

EVERY MODULE TODAY CLIMBS ONE STEP.

LOCK — HOW A HUNT IS SHAPED

- **L — Learn:** what triggered this hunt? Intel, an anomaly, a gap.
- **O — Observe:** the hypothesis and the query. What behavior would this actor leave?
- **C — Check:** run it, triage it, rule things out. Dead ends count.
- **K — Keep:** the finding, the SPL, the verdict. `athf similar` reads this later.

> A ruled-out hypothesis is still a finding.

LEARN → OBSERVE → CHECK → KEEP. THEN KEEP FEEDS THE NEXT LEARN.

THE ENVIRONMENT + SAFETY

- **Splunk** — grab your server URL + creds from the shared spreadsheet (we'll point you to it). All data lies in `index=thrunt`. Read-only.
- **EvidenceForge** — Talos's open-source, behavior-driven telemetry engine. Deterministic, fully synthetic, reproducible from a seed.
- **Pods** — five pods of eight. Talk to each other; collaborate; you learn this by watching someone pivot.
- **Hints** — stuck more than a few minutes? Flag a staffer. Using hints is not cheating.

THE SHAPE OF THE DAY

1. **Manual + structure** — hunt by hand to learn why it doesn't scale (60 min)
2. **Search + similarity** — reuse what you built (45 min)
3. **Research agents** — AI generates hypotheses from intel (40 min)
4. **Agentic MCP** — the agent finds your blind spots (40 min)
5. **The pivot** — same actor, new TTP, 25 min, no hand-holding (30 min)

WATCH THE GAP OPEN. THAT'S THE LESSON.

/\/ nebulock

MANUAL HUNTING & STRUCTURE

FEEL THE PAIN OF AD-HOC HUNTING. EARN THE CURE.

MEET THE VICTIM: SUDO SHIPPING. FLEET LOGISTICS, MOVE FAST, SHIP FASTER.

SUDO SHIPPING'S SOC, RIGHT NOW. THEY DON'T KNOW YET.

WHY WE START BY HAND

- **The intrusion:** Sudo Shipping — devs install build tooling from a public registry, no procurement gate.
- A backdoored patch of a popular CLI ran at install time, with developer privileges.
- **The binary is signed. The hash is clean in every feed. There is no CVE.**
- You cannot hash your way out of this. The only way in is behavior.

THE BEHAVIORAL MINDSET

- **Pyramid of Pain:** hashes and IPs are trivial to change; TTPs are expensive.
- CRON GOBLIN gives you nothing at the bottom — clean hash, CDN-looking domain.
- **Hunt the shape, not the string:** trusted-dev-process → unexpected shell → recon.
- A `node` post-install spawning `cmd.exe`, then `whoami /all` + `net group "Domain Admins"` — that's not a build step.

LOCK, CONCRETELY — `ATHF HUNT NEW`

LETTER	MEANING	MAPS TO
L — Learn	WHAT MOTIVATED THIS HUNT?	`--threat-context` / `--actor`
O — Observe	THE TESTABLE STATEMENT.	`--hypothesis` / `--behavior`
C — Check	TRIAGE IN SPLUNK, RULE THINGS OUT.	findings section
K — Keep	SPL, VERDICT, RULED-OUT BRANCHES.	what makes it *reusable*

ABLE — THE HYPOTHESIS IS A SENTENCE

Actor	CRON GOBLIN
Behavior	POST-INSTALL SCRIPT SPAWNS A SHELL
Location	DEVELOPER WORKSTATIONS
Evidence	`NODE` → `CMD.EXE` PARENT/CHILD IN EDR PROCESS EVENTS

> "CRON GOBLIN uses a post-install script to spawn a shell on developer workstations; evidence is a `node` → `cmd.exe` parent/child in EDR." **If you can write it, you can hunt it.**

WHAT "DONE" LOOKS LIKE

A finished hunt is **not** "I found the thing." It's:

1. A hypothesis someone else could read and re-run.
2. The exact SPL you used.
3. A verdict: confirmed / not-found / needs-follow-up.
4. Everything you ruled out → including the red herrings.

This module you write two: `H-D01` (post-install execution chain) and `H-D02` (unusual outbound after install). Both are Tier-1 — findable in the search bar.

OPEN THE LAB

- Hunt Sudo Shipping by hand in Splunk.
- Scaffold `H-D01` and `H-D02` with `athf hunt new` as you go.
- Fill LOCK. Write the ABLE sentence. Keep what you ruled out.

THE SHAPE YOU WRITE DOWN IS THE ASSET. NOW GO FIND IT.

/\/ nebulock

SEARCH & SIMILARITY

THE HUNT YOU WROTE DOWN STARTS PAYING RENT.

THE RIGHT COMMAND TURNS "NO" INTO "OKAY." SO DOES THE RIGHT CORPUS.

THE QUESTION MODULE 1 COULDN'T ANSWER

- You found WS-BUILD-01. **Was it the only victim?**
- Search the same host, same day, same command — and you miss the second one entirely.
- CRON GOBLIN time-shifted install two: over a day later, different developer's box, inside a legit build window.

> Keyword search only finds more of exactly what you already saw.

BEHAVIOR IS THE REUSABLE UNIT

- In H-D01 you wrote a shape: **trusted-dev-process → unexpected shell → recon child.**
- That sentence is host-agnostic, time-agnostic, user-agnostic.
- Indicators rot — the IP, the domain, the hostname all change on the next box.
- Pivot the *shape* across all hosts and all time, and the second victim falls out.

TWO COMMANDS DO THE L2 WORK

COMMAND	QUESTION IT ANSWERS
`athf similar --hunt H-D01`	"WHAT HAVE I HUNTED LIKE THIS BEFORE?"
`athf similar "post-install shell recon"`	FREE-TEXT AGAINST YOUR CORPUS
`athf hunt coverage`	"WHAT HAVE I *NOT* HUNTED?"
`athf hunt coverage --detailed`	TECHNIQUE-TO-HUNT MAPPING

WHAT YOU'LL DO IN THE LAB

1. Run `athf similar` / `coverage` to orient from your Module 1 hunts.
2. Take the H-D01 shape and pivot it host-agnostic and time-agnostic in Splunk.
3. Find the **second-wave victim** (A4) — different host, a day-plus later.
4. Write it as **H-D03** — noting the behavioral pivot, not a keyword search, surfaced it.

OPEN THE LAB

- Ask your corpus, not the search bar.
- Pivot the behavior across every host and all time.
- Write `H-D03` and name what found it.

YOU FOUND A VICTIM YOU HAD NO INDICATOR FOR. BECAUSE YOU WROTE THE BEHAVIOR DOWN.

/\/ nebulock

AI RESEARCH AGENTS

THE AGENT GENERATES THE HYPOTHESIS. SPLUNK CONFIRMS IT.

RESEARCH IS THE STEP BEFORE THE HUNT

- Everything so far was **hunting**: you had a hypothesis, you tested it.
- **Research** is the step *before* the hypothesis — read intel, understand tradecraft, generate directions.
- Two objects in ATHF: a **research doc** (`athf research new`) proposes; a **hunt** (`athf hunt new`) tests.
- Research feeds hunts. Link them: `athf hunt new --research R-0001`.

WHERE YOU'RE STUCK WITHOUT RESEARCH

- Module 2 left an open thread: H-D02's beacon to `cdn-packmule-telemetry.net`.
- You **observed** it. You couldn't **characterize** it.
- Is 5-minute periodicity meaningful? How would you link this domain to *other* actor infra? Is there a low-and-slow second channel?
- **That's a knowledge gap, not a data gap.** The events are right there.

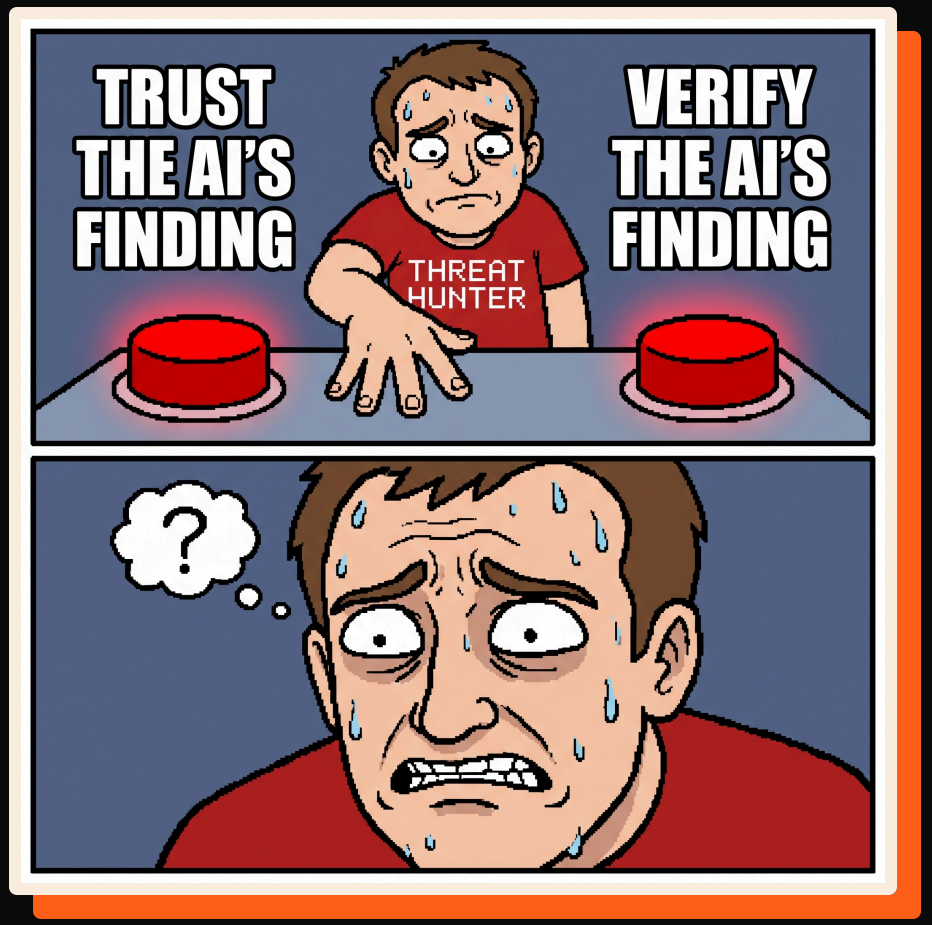
ATHF RESEARCH NEW

```
athf research new \
  --topic "HTTPS beacon detection: infrastructure-reuse pivoting (JA3 / shared C2 infra)" \
  --technique T1071.001 \
  --depth basic
```

- `--topic` (required) — the research question.
- `--technique` — anchor to an ATT&CK ID so it links to hunts.
- `--depth basic` ≈ 5 min · `advanced` ≈ 15–20 min. **Use `basic` in the lab.**
- `--no-web-search` — offline mode when the network is flaky.

L3 IS THE FIRST PLACE THE AI CAN BE CONFIDENTLY WRONG

- **Research generates hypotheses; it does not confirm them.** Confirmation lives in Splunk, not the doc.
- **It assumes fields you don't have.** The agent says pivot on JA3 — your Zeek `ssl` has no `ja3` column. Adapt the *idea* to the field you have: the shared hosting block `203.0.113.44/30`.
- **It costs tokens and time.** Research deliberately, not reflexively (`--workshop --token-cap`).



THERE'S ONLY ONE BUTTON. VERIFY. ALWAYS VERIFY.

OPEN THE LAB

- Run `athf research new` on the beacon you couldn't characterize.
- Read the doc critically — every concrete claim is a lead, not a fact.
- Pivot on what it tells you. Confirm in Splunk. Write the hunt.

LET RESEARCH CRACK THE BEACON. LET THE DATA CONFIRM IT.

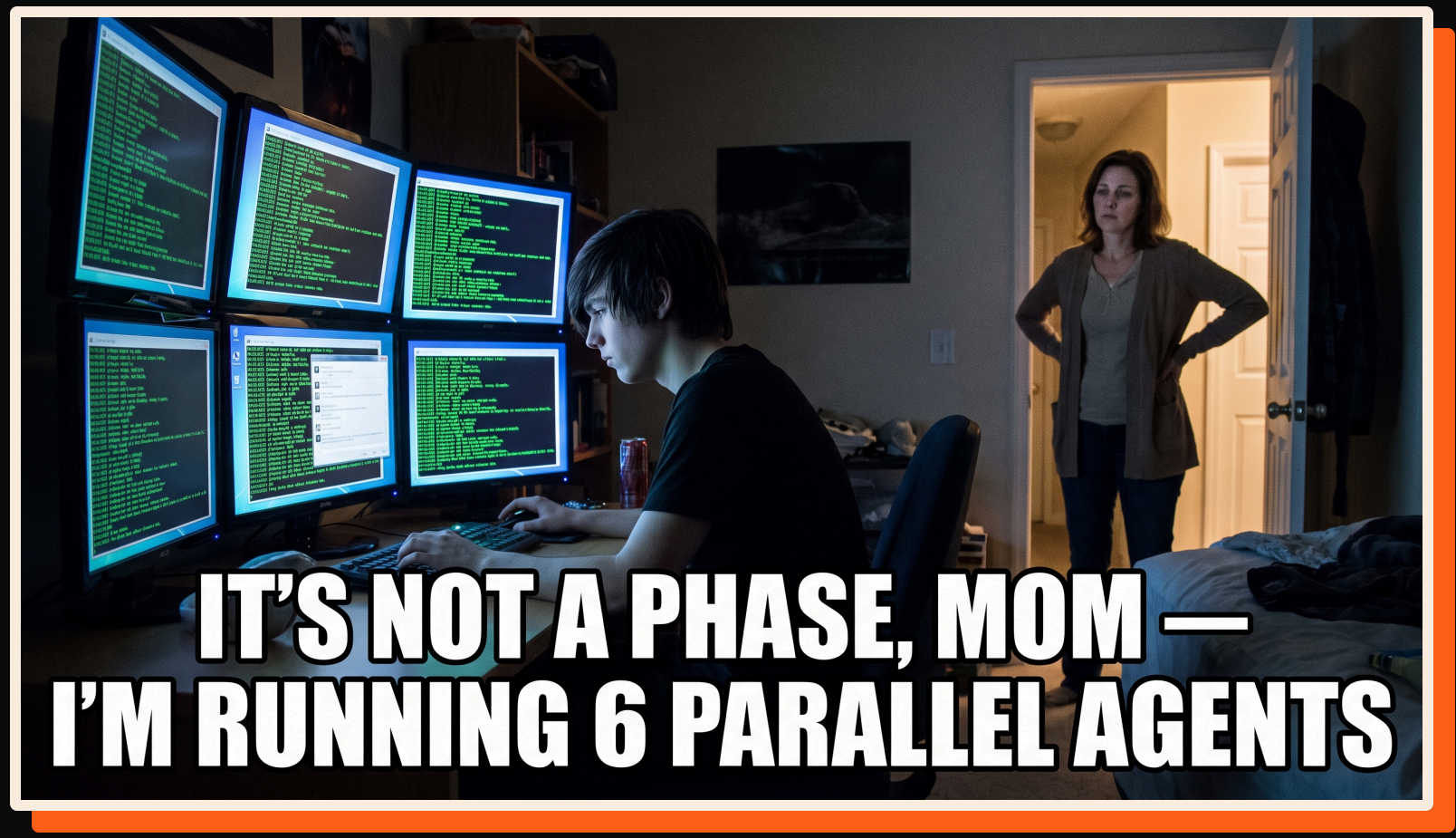
/\/ nebulock

FULL AGENTIC HUNTING VIA MCP

THE AGENT READS YOUR REPO AND NAMES WHAT YOU MISSED.

WHAT CHANGES AT L4

- **L3:** the agent read *the world* — threat intel — and gave you hypotheses.
- **L4:** the agent reads *your work* — your corpus, your coverage — and names *your* blind spots.
- L3 explains DNS tunneling in general. L4 says: **"you have C2 and cred-access covered, nothing on exfil — here's the query."**
- It knows what *you* haven't done because it can see your repo.



AT L4 THIS ISN'T A BIT. PARALLEL AGENTS, ALL READING YOUR REPO.

MCP IN ONE SLIDE

- **MCP (Model Context Protocol)** — a standard way to hand an AI client callable tools.
- `athf-mcp-server` exposes ATHF operations as tools; point Claude Code (or your client) at it.
- Now the agent queries your hunt repo directly — no copy-pasting into a chat window.
- Every tool returns structured context **plus** instructions — the agent reasons over real data, not a summary.

THE TOOLS THE SERVER EXPOSES

TOOL	WHAT IT DOES
`generate_hunt_hypothesis`	PROPOSE A HYPOTHESIS FROM INTEL
`search_hunts_by_text`	FULL-TEXT SEARCH ACROSS YOUR CORPUS
`find_similar_hunts`	THE MCP FORM OF `ATHF SIMILAR`
`list_coverage_gaps`	**THE STAR:** WHICH PHASES HAVE NO HUNT YET
`propose_next_query`	TURN THE BIGGEST GAP INTO A CONCRETE QUERY

WHY COVERAGE-GAP DETECTION IS THE WHOLE POINT

- Modules 1–3 found what you *went looking for*.
- The two hardest artifacts — cred-access (A9) and DNS-tunnel exfil (A10) — share one property: **you don't know you haven't found them.**
- No open thread points at them. At L0–L2 you simply *stop*.
- `list_coverage_gaps` reads your hunts, maps kill-chain phases, reports: **cred-access ✕, exfil ✕.**

YOU DRIVE IT IN PLAIN ENGLISH

- You will **not** type `list_coverage_gaps`.
- You ask what you'd ask a senior hunting partner: **"What have I hunted?"** / **"What should I hunt next?"**
- The agent picks the tool. Your corpus becomes something you *talk to*.
- Tool names stay as a fallback — offline, or when a question misfires.

YOU ASK IN PLAIN ENGLISH. THE AGENT PICKS THE TOOL.

OPEN THE LAB

- Connect your MCP client. Ask what you've hunted.
- Ask what to hunt next. Chase the two Tier-3 gaps it names.
- Produce `H-D05`. End on "ask your repo anything."

THE FRAMEWORK REMEMBERS WHAT YOU HUNTED - SO THE AGENT CAN TELL YOU WHAT YOU DIDN'T.

/\/ nebulock

SAME ACTOR, NEW TTP

SAME ACTOR. NEW BATTLEFIELD. 25 MINUTES. GO.

CRON GOBLIN. THE ACTOR YOU'VE HUNTED ALL DAY JUST CHANGED THE GAME.

THE PIVOT

> "New intel on CRON GOBLIN — the same actor behind the trojanized `packmule-cli` — shows they've pivoted. No more waiting for developers to install a bad package. They've compromised a maintainer's access to a trusted internal repo and are injecting malicious build steps straight into your CI/CD pipeline. The runner does the work now. Same actor. Same infrastructure. New technique. The new campaign is already in your Splunk. You have 25 minutes. Go."

THIS IS THE WHOLE INTRUSION, ON ONE SCREEN.

WHY THE PREPARED HUNTER WINS

- **Documented Campaign 1:** a repo full of hunts on C2, cred-access, exfil — the exact behaviors CRON GOBLIN reuses.
- `athf similar` + MCP links the new artifacts to old hunts in seconds. **"Same actor, new host"** falls out for free.
- **Worked ad-hoc (L0):** you'd have nothing to reuse. A blank search bar against unfamiliar CI telemetry.

> Watch the gap between those two hunters. That gap is the product.

THE UN-HUNTED ATTACKER'S WHOLE ADVANTAGE IS TIME YOU DIDN'T SPEND LOOKING.

YOUR 25 MINUTES

- No prescribed path — **pick your level.** But if you have a corpus, the fast route is obvious:

1. New CI process events — a `curl | sh` build step nobody committed.
2. Your cred-access structure (H-D05) transfers to the runner stealing cloud creds.
3. `athf similar` your C2 hunts → links the runner's beacon to Campaign-1 infra. **That's the proof.**
4. Exfil to cloud storage closes it out.

THE CLOCK STARTS NOW

- Produce at least one hunt — `H-D06` — documenting the CI-runner compromise.
- If you can, cite the earlier hunt it reused.

THAT CITATION IS THE WHOLE STORY IN ONE LINE: THE FRAMEWORK REMEMBERED WHAT YOU HUNTED.

/\/ nebulock

WHAT YOU BUILT, AND WHAT'S NEXT

FOUR HOURS. FOUR TO SIX HUNTS. ALL YOURS.

THE ARC YOU JUST WALKED

LEVEL	WHAT YOU DID	TOOL
L0	HUNTED IN A SEARCH BAR.	—
L1	WROTE THE HUNT DOWN.	`athf hunt new`
L2	BEHAVIOR FOUND A HIDDEN VICTIM.	`athf similar`
L3	AN AGENT NAMED WHAT TO HUNT.	`athf research new`
L4	AN AGENT NAMED YOUR BLIND SPOT.	MCP

EACH LEVEL ONLY WORKED BECAUSE THE ONE BELOW IT WROTE SOMETHING DOWN.

THE MOMENT THAT MATTERED

- **Module 5**: Same actor, new battlefield, 25 minutes.
- Documented hunters linked the CI beacon to Campaign-1 infra in seconds — *"same actor, new host."*
- The ad-hoc hunters started **cold**.

THAT GAP IS THE WHOLE THESIS: MEMORY IS THE EDGE. NOT A BIGGER MODEL. THE FACT THAT YOU WROTE IT DOWN.

BEHAVIOR OVER INDICATORS

- The binary was signed. The hash was clean. There was no CVE.
- Every artifact you found today was **behavioral** → a shape that transfers across hosts, time, and infrastructure.
- Indicators rot. Behavior persists. It is the durable signal.

THAT'S NOT A SLOGAN. YOU JUST SPENT FOUR HOURS PROVING IT.

BURY THE INDICATOR. KEEP THE BEHAVIOR.

IT'S ALL YOURS

- **ATHF is open source, on PyPI.** Vendor-neutral by design.
- OpenAI and Anthropic both ran in this room today — the tool works with others too.
- Nothing you learned is locked behind a login.

TAKE THE REPO. TAKE THE WORKFLOW. RUN IT AGAINST YOUR OWN TELEMETRY MONDAY.

TAKE THE REPO. TAKE THE WORKFLOW. RELISH THE HUNT.

THE SIBLING QUESTION

- You hunted these behaviors *once*.
- The obvious next question: how do you catch them *every* time, automatically, with no human in the loop?
- **Hunting finds the unknown. Detection operationalizes the known.**

THAT HAND-OFF — HUNT → DURABLE DETECTION — IS WHERE MOST TEAMS LOSE THEIR WORK.

THE SUPPLY CHAIN GIVETH. SOMETIMES IT GIVETH A GOBLIN.

ADEF — THE SIBLING FRAMEWORK

- **ADEF — the Agentic Detection Engineering Framework.** ATHF's sibling.
- ATHF asks *"what happened that we didn't know about?"*
- ADEF asks *"how do our findings become detections that never miss it again?"*
- Same philosophy — behavior-first, memory-first, AI-augmented, open — pointed at the detection lifecycle.

THE THROUGH-LINE

- The shared-infra beacon becomes a **correlation rule.**
- The uncommitted CI step becomes a **pipeline-integrity detection.**
- The cred-access shape becomes a **behavioral analytic.**

YOUR HUNTS ARE THE INPUT TO DURABLE DETECTIONS. THE TWO FRAMEWORKS FORM ONE LOOP.

TAKE THESE WITH YOU

- `ATHF:` `pip install agentic-threat-hunting-framework` — github.com/Nebulock-Inc/agentic-threat-hunting-framework
- `ADEF:` landing page bookmark
- `This workshop's open materials` — pre-read, provider configs, preflight validator.
- `The survey` — 90 seconds, it genuinely shapes the next one.

THANK YOU FOR HUNTING WITH US.

/\/ nebulock

ONE LAST THING

Poked at the weird stuff?
The hot-dog service account, the Pokémon on the dev VLAN, the `hunter2` in a `.env`? This one's for you.

THE GLIZZARD SALUTES THE CURIOUS. STAY CURIOUS. HUNT WEIRD.